ScanSuite
Administration Manual

Version 0.4 Draft 01.03.2024

Author: Sergey Egorov

Contents

Introduction....3
Installation....4
Advanced setup parameters and services....10
Administration....12

Introduction

ScanSuite is a security scanning orchestration software which automates the process of code static analysis, dynamic website, and infrastructure scanning. It takes the user supplied input, such as an archive with the source code, website URLs or hosts IP and invokes the original scanners, chosen by the user.

ScanSuite neither embeds the scanners, nor performs vulnerability scanning itself. Instead, it implements connectors to various vulnerability scanners and invokes them with optimal parameters. If the respective scanner is not installed, ScanSuite will download and install it on the worker node.

After the scan is finished, ScanSuite will upload the results to the vulnerability management system DefectDojo, where these can be visualized and processed.

A high-level diagram, describing the components, is given below. Here, the user input is accepted via web interface, command line or CI/CD management console.

The next chapters describe how to install, configure, and administrate ScanSuite.

Installation

ScanSuite and all components it works with are dockerized and therefore can be installed to any operating system, supporting docker.

Here are some prerequisites for the successful installation:

1. Technical requirements depending on the number of parallel scans invoked and the scanners used. Minimum it should be **3 CPU cores, 12Gb RAM and 70Gb of free space on SSD**. That should be enough to store all supported scanners locally and run 2 parallel scans, including the most resource consuming ones.
2. **Docker and docker-compose** will be auto installed by the installer on Ubuntu and Debian Bookworm / Kali distributions by the software installer. For other OS please manually install these components.
3. **Defect Dojo** is used to view and manage scan results. It can be auto installed on the same host as ScanSuite by the installer. It can also be installed the separate host too as soon as it is reachable by ScanSuite over https.
4. To install and run the product, the following is required:
    a. **Key file** company_name_keyID.lic
    b. **Password** to download and update ScanSuite containers.
    c. **NTP server** should always be accessible by ScanSuite. By default, the Internet accessible NTP pool.ntp.org is set.

As soon as the requirements above are met, ScanSuite installation is straightforward:

1. Download the installer to the **user's home** directory:

    cd
    git clone https://github.com/myappsec/scansuite

    ```
    scanbot@scansuite:~$ cd
    scanbot@scansuite:~$ git clone https://github.com/myappsec/scansuite
    Cloning into 'scansuite'...
    remote: Enumerating objects: 165, done.
    ```

2. Copy the key file to the **scansuite/key** directory and run the installer from the scansuite folder with the following parameters:

    ./install KeyID dojo

Here the Key ID is a 6 characters string copied from the key file name.

dojo – optional parameter to install Defect Dojo on the same host as ScanSuite.

```
scanbot@scansuite:~/scansuite$ mv ~/egorov-sergey_222166.lic key/
scanbot@scansuite:~/scansuite$ ./install 222166 dojo
Installing DefectDojo ...
mkdir: cannot create directory '/home/scanbot/apps': File exists
Cloning into 'django-DefectDojo'...
remote: Enumerating objects: 149478, done.
remote: Counting objects: 100% (125/125), done.
remote: Compressing objects: 100% (76/76), done.
```

When prompted, paste your password (starts with **dckr_pat_** ...):

```
 ✓ Container django-defectdojo-celeryworker-1  Started
 ✓ Container django-defectdojo-initializer-1   Started
 ✓ Container django-defectdojo-nginx-1         Started
Password:
WARNING! Your password will be stored unencrypted in /root/.docker/config.json.
Configure a credential helper to remove this warning. See
https://docs.docker.com/engine/reference/commandline/login/#credentials-store

Login Succeeded
Using default tag: latest
```

Wait till all containers are downloaded and installation is finished:

```
Installation finished

Update .env params with DefectDojo secrets and run:
./start-scansuite

To get DefectDojo admin password run:
./dojo-password
scanbot@scansuite:~/scansuite$
```

3. Start ScanSuite. Provide the number of scanning workers you need (default is 2). Check the technical requirements to ensure your host can accommodate a specified number of parallel scans.

./start-scansuite **2**

The output of successful start will be the following:

```
scanbot@scansuite:~/scansuite$ ./start-scansuite
[sudo] password for scanbot:
[+] Building 0.0s (0/0)
[+] Running 8/8
 ✔Network scansuite_default           Created
 ✔Container scansuite-redis-1         Started
 ✔Container scansuite-postgres-1      Started
 ✔Container scansuite-web-1           Started
 ✔Container scansuite-worker_admin-1  Started
 ✔Container scansuite-worker-2        Started
 ✔Container scansuite-worker-1        Started
 ✔Container scansuite-nginx-1         Started
scansuite-worker-1  | [2024-03-01 16:09:08,981: INFO/MainProcess] celery@9ed1ba344fd2 ready.
scansuite-worker-2  | [2024-03-01 16:09:09,278: INFO/MainProcess] celery@36c94fe90c14 ready.
2024-02-18 11:05:50,165:INFO:admin user created with password: GMmnVztZOaDAoSMFU
```

Note down the scansuite admin username and password.

If you get the different output, first ensure the license key is in the respective **/key** folder and the **NTP server**, defined in the license, is reachable by the host. Once again execute:

./start-scansuite **2**

4. Check the Defect Dojo admin password and get its API key

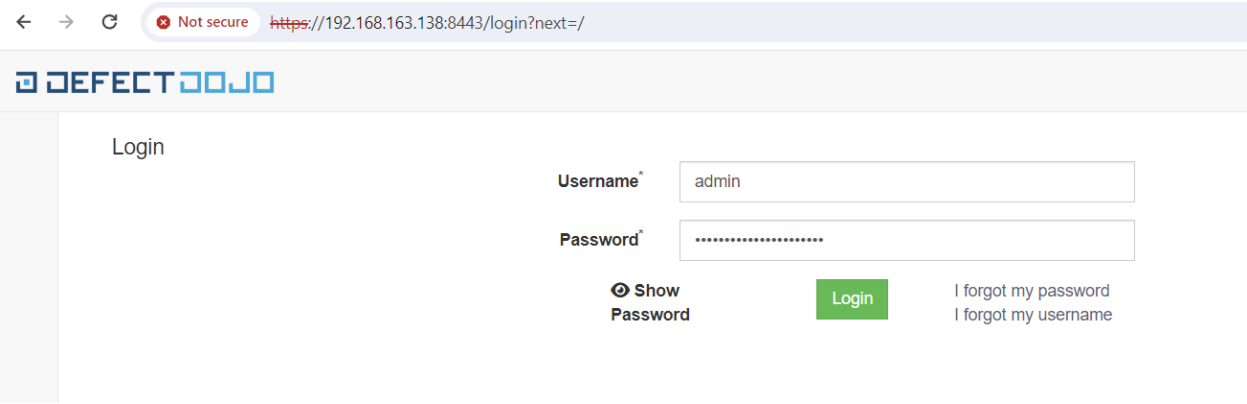
./dojo-password

```
scanbot@scansuite:~/scansuite$ ./dojo-password
WARN[0000] The "DD_DATABASE_HOST" variable is not set. Defaulting to a blank string.
WARN[0000] The "DD_DATABASE_PORT" variable is not set. Defaulting to a blank string.
```

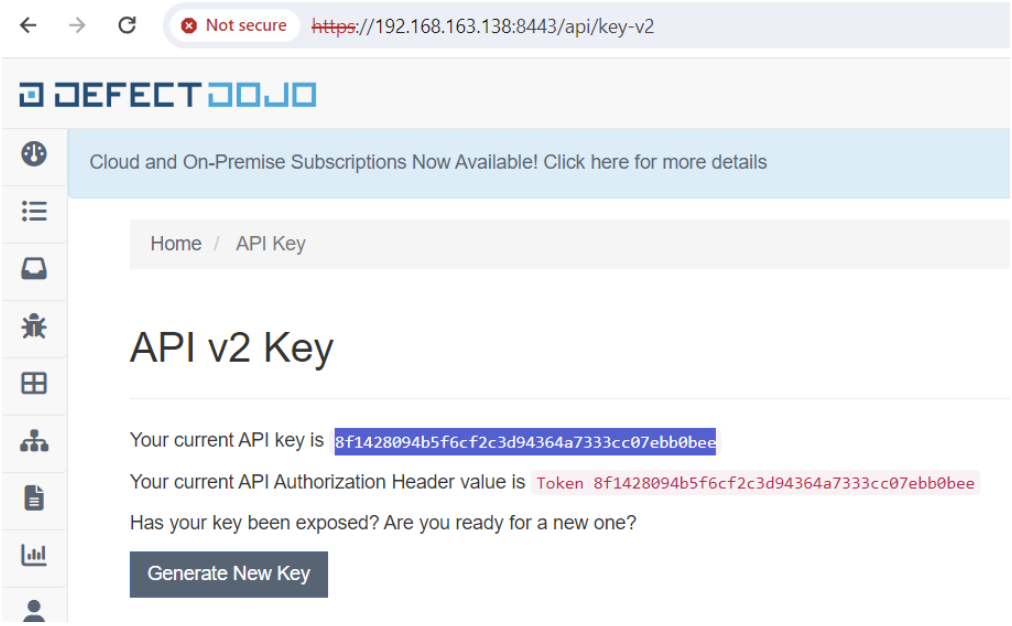
```
WARN[0000] The "DD_DATABASE_USER" variable is not set. Defaulting to a blank string.
WARN[0000] The "DD_DATABASE_PASSWORD" variable is not set. Defaulting to a blank string.
django-defectdojo-initializer-1  | Admin password: g1WKfDzhHQgtmoUCxMfODp
```

Note: This checks the password in the auto installed Defect Dojo folder **~/apps/django-DefectDojo** folder. If you have a separate Defect Dojo installation, refer to its documentation on how to get or renew the password.

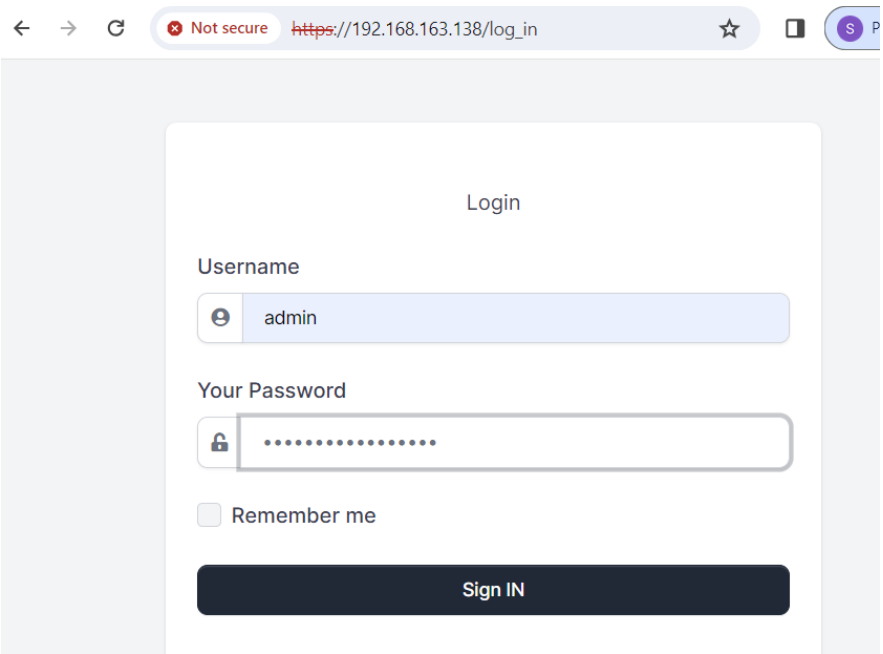
Open the browser and login to Defect Dojo via *https://YOUR_HOST_IP:8443*:



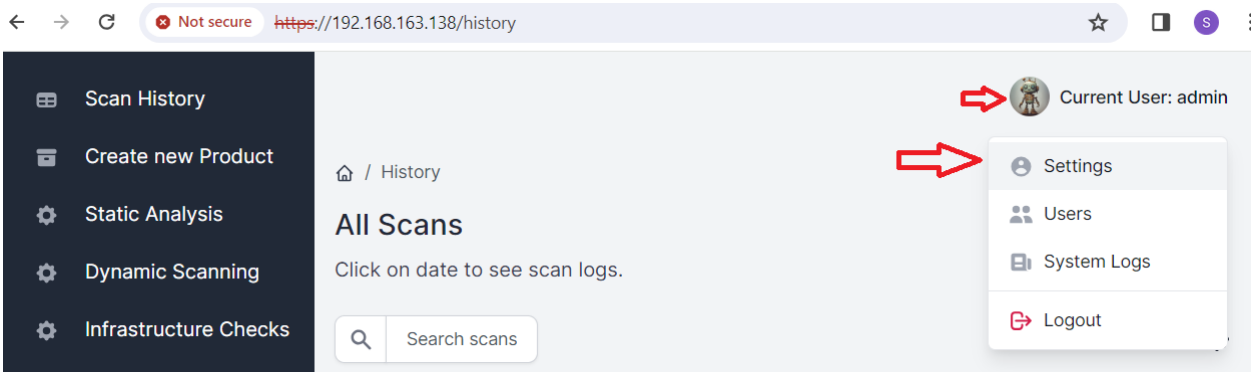
Follow to **/api/key-v2** path and copy the API key:



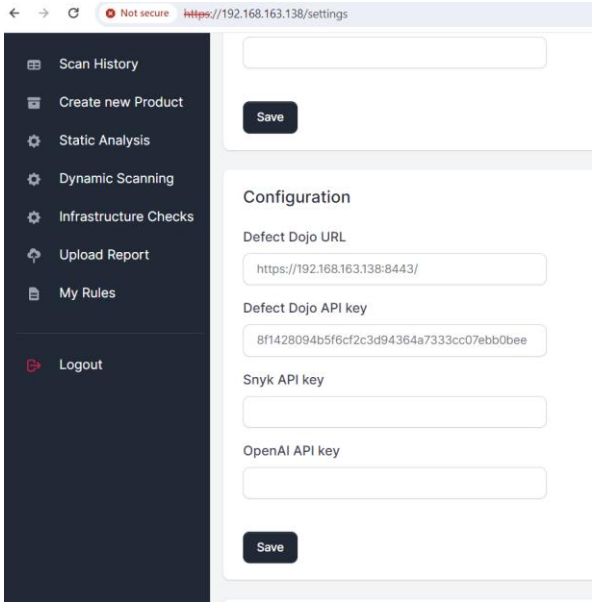
Login to the ScanSuite over *https://YOUR_HOST_IP*



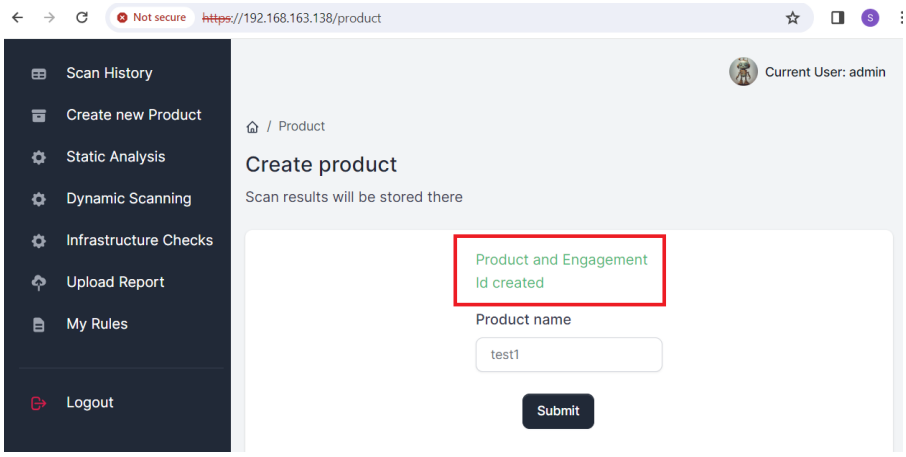
Follow to the Settings menu:



Paste the Defect Dojo host URL and API key, click Save:



Follow to the Create new Product and create a test product. If everything is set correctly, the product will be created:



Advanced setup parameters and services

ScanSuite components, such as the database or the MQ can be set on the different hosts. In such case, connection strings and credentials should be passed via the **.env** file which can be located in the scansuite folder:

```
scanbot@scansuite:~/scansuite$ cat .env
ENABLE_STATIC_SCANS=True

LOG_FILE=/var/tmp/scansuite.log

CELERY_HOST=redis
REDIS_PASSWORD=your_secure_password

PS_DATABASE_HOST=postgres
PS_DATABASE_NAME=scansuite
PS_DATABASE_USER=scansuite
PS_DATABASE_PASSWORD=secure_password
```

LOG_FILE – the ScanSuite log file, should be reachable from the container. By default, only **/var/tmp** is mounted to the container, adjust the docker-compose.yml to mount other folders for an alternative log storage.

CELERY_HOST and **REDIS_PASSWORD** – Redis connection parameters

PS_DATABASE_ – PostgreSQL database connection parameters

ENABLE_STATIC_SCANS – True by default, set to False to disable code static analysis functionality.

Additionally, several binaries were created for you to help with typical administrative activity. These are:

install – for ScanSuite and Defect Dojo installation and update.

dojo-password – retrieves Defect Dojo password from default ~/apps/django-DefectDojo location. Note that password is removed in a few days after generation, note it down and save in secure location.

start-scansuite – use to start or restart ScanSuite stack.

services/offline – downloads all scanner images if intended to be used in the offline network segment.

services/reset-dojo – wipes the Defect Dojo in default location database to start from scratch.

services/reset-scansuite – wipes the ScanSuite database in default location.

Note: After execution of **reset-** binaries new admin passwords and API key will be generated on startup. For DefectDojo you need to wait a few minutes before the new DB is initialized and admin user created. Do not forget to fetch the new Defect Dojo API key and update ScanSuite **Settings** respectively.

services/nginx/certs – place your custom SSL private key and certificate in .pem format for ScanSuite web server.

services/nginx/scan-dojo.example – the example nginx config to enable reverse proxy for both ScanSuite and Defect Dojo via one nginx instance. This is recommended in case of custom SSL certificates will be used for Defect Dojo, instead of the default self-signed.

Administration

ScanSuite administration functionality includes the following:

- Setting API keys for external systems
- User administration
- System logs examination
- Clear the scan results history.

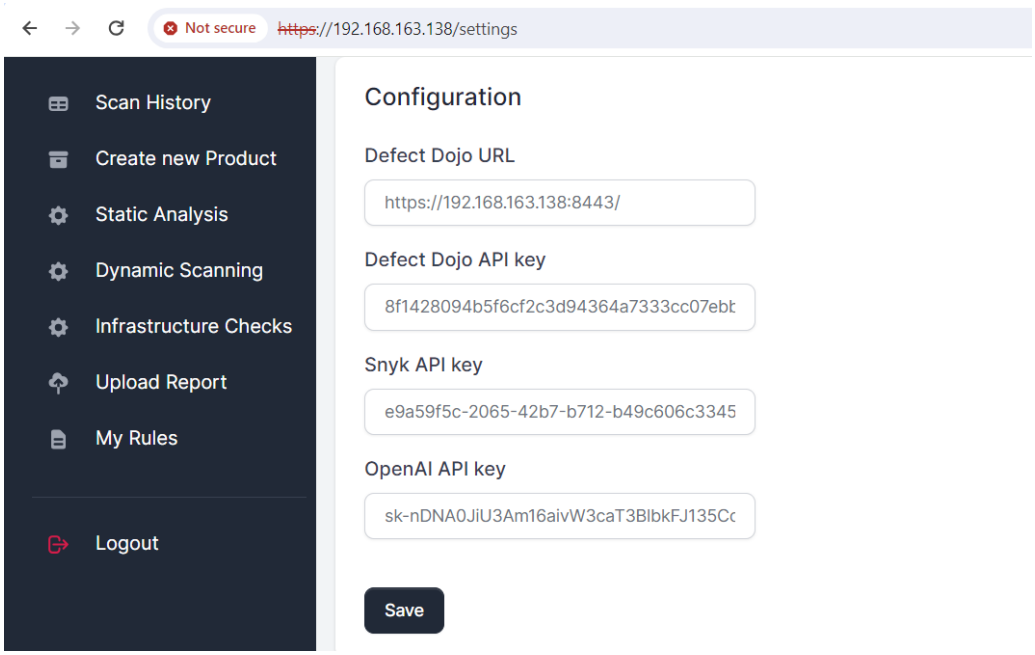
1. Set the API keys via Settings.

Snyk API key is required for Snyk scans. Can be obtained for free by following the steps below:

- Create an account on Snyk https://app.snyk.io/login
- GoTo https://app.snyk.io/org/cepxeo/manage/snyk-code and Enable Snyk Code
- Follow to https://app.snyk.io/account/ and create the Auth Token

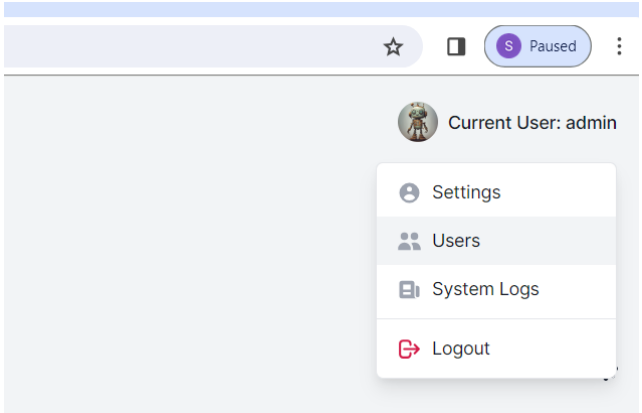
OpenAI API key is required for AI generated content such as rules and static code analysis. Could be obtained here: https://platform.openai.com/api-keys

Fill in the keys the same way as the Defect Dojo connection parameters to respective Settings fields and click Save:



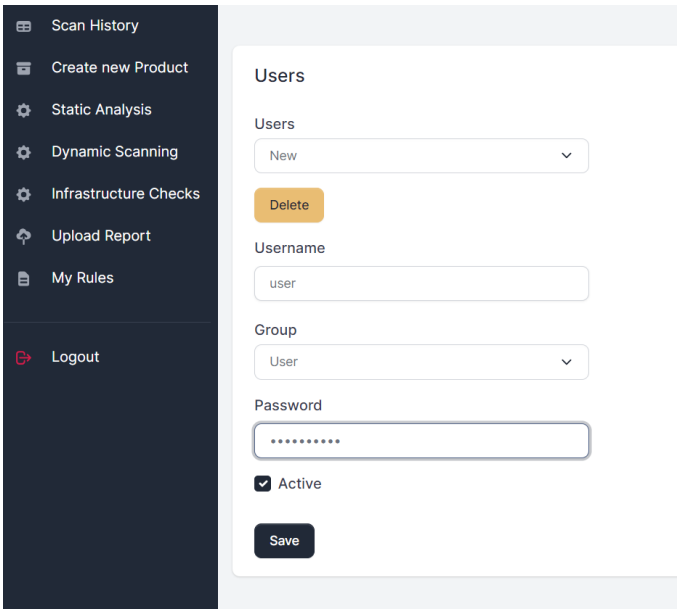
2. User administration

Is accessible via top right corner context menu -> Users

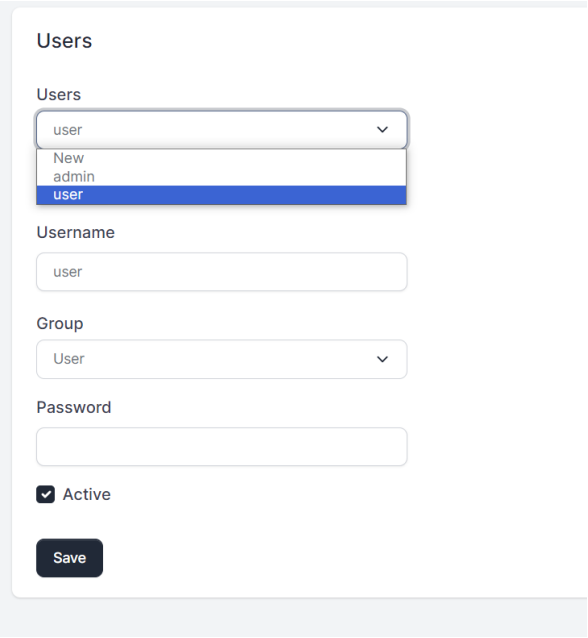


Administrators can create, delete, deactivate users, and change their passwords.

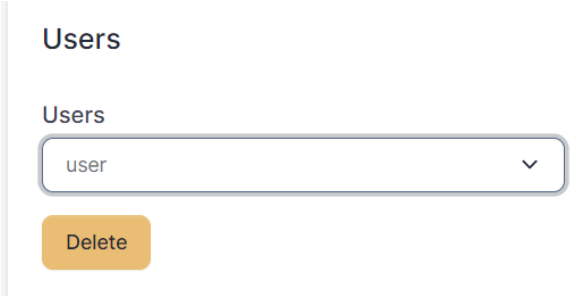
To create the user, fill in respective field and click Save:



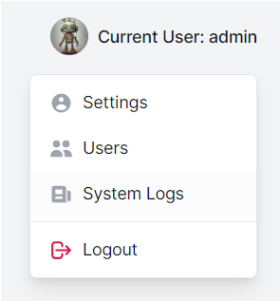
To change the user's password, group or activation status choose it from the dropdown menu:



To delete the user, choose it from the dropdown menu and click Delete:

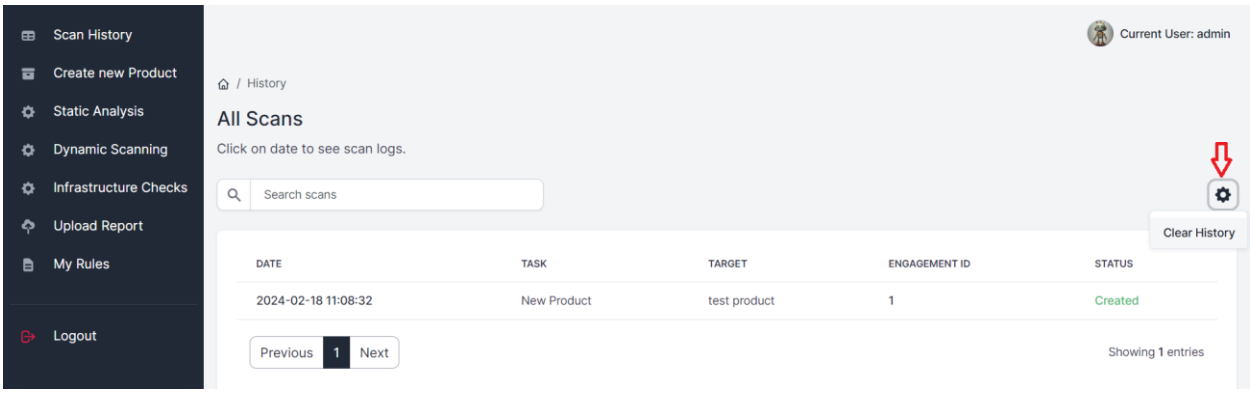


3. System logs are available via to right context menu -> Systems Logs



All users and administrators' activity are recorded there along with critical application errors:

2024-02-18 11:17:35,662	WARNING	User user logged in
2024-02-18 11:17:39,213	WARNING	User user logged out
2024-02-18 11:17:48,311	WARNING	User admin logged in
2024-02-18 11:19:19,868	WARNING	User admin created new user record user1
2024-02-18 11:20:17,727	WARNING	User admin updated user record user
2024-02-18 11:52:42,586	WARNING	User admin tried to delete admin user record user
2024-02-18 11:53:36,413	WARNING	User admin updated user record user

4. Clear History

To clear the Scan History, select the cog icon and Clear History. All information about past scans, including the saved artifacts, will be wiped.